

(a) Modelo de Encuesta Integral SOC 2 – España 2026

Encuesta dirigida a responsables de ciberseguridad, riesgo, cumplimiento, tecnología y dirección en organizaciones que desean evaluar su alineamiento con SOC 2, ENS, NIS2 y marcos afines.

1. Información general de la organización

1.1 Tipo principal de organización (puede marcar más de una opción si procede):

- ☐ Organismo de la Administración General del Estado
- ☐ Administración autonómica
- ☐ Administración local (ayuntamiento, diputación, cabildo, etc.)
- ☐ Entidad pública empresarial / agencia / consorcio
- ☐ Operador esencial NIS2 (energía, salud, transporte, agua, etc.)
- ☐ Operador importante NIS2
- ☐ Proveedor cloud / SaaS / MSP / datacenter
- ☐ Entidad financiera / seguros
- ☐ Empresa industrial / manufactura
- ☐ Otro (especificar): _____

1.2 Tamaño aproximado de la organización (empleados):

- ☐ < 50
- ☐ 50 – 249
- ☐ 250 – 999
- ☐ 1.000 – 4.999
- ☐ ≥ 5.000

1.3 Ámbito geográfico principal de operación:

- ☐ Local / regional
- ☐ Nacional
- ☐ Unión Europea
- ☐ Global

1.4 Rol de la persona que responde:

- ☐ CISO / Responsable de Seguridad de la Información
- ☐ CIO / CTO / Responsable TIC
- ☐ Responsable de Riesgos / Cumplimiento / Auditoría Interna
- ☐ Dirección General / Miembro del Consejo / Comisión
- ☐ Otro (especificar): _____

2. Gobernanza y entorno de control (CC1)

2.1 ¿Dispone la organización de una estrategia formal de ciberseguridad aprobada por la alta dirección o el órgano de gobierno correspondiente?

- ☐ No existe como documento formal; vivimos de iluminaciones puntuales.

- ☐ Existe un documento interno, pero no ha sido aprobado formalmente por la alta dirección.
- ☐ Existe y ha sido aprobada por la alta dirección, pero no se revisa periódicamente.
- ☐ Existe, está aprobada y se revisa al menos cada dos años.
- ☐ Existe, está aprobada y se revisa al menos anualmente, con indicadores asociados.

2.2 En relación con los objetivos de ciberseguridad, ¿cuál de las siguientes opciones describe mejor la situación actual?

- ☐ No se han definido objetivos específicos de ciberseguridad.
- ☐ Hay objetivos cualitativos ("mejorar la seguridad", "reducir riesgos") sin métricas asociadas.
- ☐ Hay objetivos con algunas métricas, pero sin metas temporales claras.
- ☐ Los objetivos tienen métricas y metas temporales definidas, pero su seguimiento es irregular.
- ☐ Los objetivos tienen métricas y metas claras y se revisan sistemáticamente con la alta dirección.

2.3 ¿Con qué frecuencia se presenta información estructurada de ciberseguridad (riesgos, incidentes, métricas) a la alta dirección o al órgano de gobierno?

- ☐ Solo cuando ocurre un incidente grave o se aproxima una auditoría.
- ☐ Menos de una vez al año.
- ☐ Anualmente.
- ☐ Trimestralmente.
- ☐ Mensualmente o con frecuencia superior, mediante cuadros de mando.

2.4 ¿Qué grado de implicación tiene la alta dirección en decisiones de inversión en ciberseguridad?

- ☐ Delegadas casi por completo a TI; la dirección aparece al final para firmar.
- ☐ La alta dirección participa ocasionalmente, sin un proceso estructurado.
- ☐ Existe un proceso formal, pero la discusión suele centrarse en cumplimiento mínimo.
- ☐ Existe un proceso formal con evaluación de riesgos y retorno esperado.
- ☐ La ciberseguridad se discute regularmente al nivel del resto de prioridades estratégicas.

2.5 ¿Dispone la organización de una figura responsable de seguridad claramente designada (CISO o equivalente) con autoridad y responsabilidades definidas?

- ☐ No existe una figura claramente definida; todos y nadie son responsables.
- ☐ Hay un responsable informal, sin funciones documentadas.
- ☐ Existe un responsable con funciones documentadas, pero sin independencia clara.
- ☐ Existe un responsable con independencia funcional y acceso a la alta dirección.
- ☐ Existe un responsable con independencia, presupuesto definido y reporte periódico al órgano de gobierno.

3. Información y comunicación (CC2)

3.1 ¿Cómo se comunican las políticas y normas de seguridad a la plantilla?

- ☐ No existen políticas formales o son desconocidas para la mayoría.
- ☐ Se envían por correo o intranet, sin evidencia de lectura.
- ☐ Se comunican y se solicita acuse de recibo o lectura, pero no se verifica.
- ☐ Se comunican, se registra su aceptación y se realizan recordatorios periódicos.

- ☐ Además de lo anterior, se realizan campañas específicas según riesgos emergentes (phishing, IA, trabajo remoto, etc.).

3.2 En materia de concienciación en ciberseguridad, indique la opción que más se aproxima a su realidad:

- ☐ No se realizan actividades formales de concienciación.
- ☐ Se realiza alguna acción puntual (p. ej. una sesión anual) sin seguimiento.
- ☐ Se realizan formaciones anuales para toda la plantilla.
- ☐ Se realizan formaciones periódicas diferenciadas por rol (técnicos, dirección, usuarios clave).
- ☐ Además, se llevan a cabo campañas de simulación (phishing, ingeniería social) con métricas de resultados.

3.3 ¿Cómo se comunica internamente la existencia de incidentes de ciberseguridad relevantes?

- ☐ De forma ad hoc y reactiva.
- ☐ A través de comunicaciones no estructuradas (correos, llamadas) según necesidad.
- ☐ Existe un protocolo de comunicación interna, pero no siempre se aplica.
- ☐ Existe un protocolo formal que se aplica de forma consistente.
- ☐ El protocolo incluye umbrales de severidad, plazos y canales para notificar a dirección, autoridades y terceros.

3.4 ¿Recibe la alta dirección informes escritos de ciberseguridad con indicadores y tendencias?

- ☐ No.
- ☐ Sí, pero de forma esporádica y sin estructura clara.
- ☐ Sí, con una estructura básica y algunos indicadores.
- ☐ Sí, con indicadores acordados, comparaciones temporales y comentarios de riesgo.
- ☐ Sí, en forma de cuadro de mando integrado con otros indicadores corporativos.

4. Evaluación de riesgos (CC3)

4.1 Respecto a la identificación y evaluación de riesgos de ciberseguridad y privacidad, ¿cuál es la situación actual?

- ☐ No se realiza un análisis de riesgos formal.
- ☐ Se realizó un análisis puntual hace más de dos años.
- ☐ Se realiza un análisis de riesgos al menos cada dos años.
- ☐ Se realiza un análisis de riesgos al menos anualmente.
- ☐ Existe un proceso continuo de gestión de riesgos con revisiones periódicas y actualización ante cambios significativos.

4.2 ¿Qué metodología utiliza la organización para el análisis de riesgos?

- ☐ Ninguna metodología definida; cada uno evalúa “a ojo”.
- ☐ Enfoque cualitativo interno sin documentación formal.
- ☐ Metodología propia documentada.
- ☐ Metodología reconocida (p. ej. Magerit, ISO 27005, FAIR, etc.).
- ☐ Combinación de metodología reconocida con herramientas automatizadas de soporte.

4.3 Aproximadamente, ¿qué porcentaje de activos y servicios críticos cuentan con análisis de riesgo actualizado en los últimos 12 meses?

- ☐ 0–20 %
- ☐ 21–50 %
- ☐ 51–80 %
- ☐ 81–99 %
- ☐ 100 % (sí, también los sistemas incómodos).

4.4 ¿Participan áreas de negocio, legales y financieras en el proceso de evaluación de riesgos, más allá del área técnica o de seguridad?

- ☐ No, se limita al área técnica/TI.
- ☐ Sí, pero de forma esporádica y sin procedimiento formal.
- ☐ Sí, con participación regular pero sin roles claramente definidos.
- ☐ Sí, con roles y responsabilidades definidos y documentados.
- ☐ Sí, y los resultados de riesgos se integran en la planificación estratégica y presupuestaria.

4.5 En relación con los proyectos que incorporan nuevas tecnologías (cloud, IA, automatización masiva, etc.), ¿cómo se evalúan sus riesgos de ciberseguridad y privacidad?

- ☐ No se realiza evaluación específica; se confía en el proveedor o en la providencia.
- ☐ Se evalúa informalmente, sin documentación clara.
- ☐ Se realiza una evaluación básica antes de la implantación.
- ☐ Se realiza evaluación formal (incluyendo DPIA cuando aplica) antes de la aprobación del proyecto.
- ☐ Además, se revisan los riesgos tras la implantación y en fases clave del ciclo de vida.

5. Actividades de monitorización (CC4)

5.1 ¿Dispone la organización de un Centro de Operaciones de Seguridad (SOC), propio o externalizado?

- ☐ No.
- ☐ Sí, pero solo para ciertos sistemas aislados.
- ☐ Sí, con cobertura limitada a horarios laborales.
- ☐ Sí, con cobertura ampliada pero no 24/7.
- ☐ Sí, con cobertura 24/7 sobre los sistemas críticos identificados.

5.2 Aproximadamente, ¿qué porcentaje de sus sistemas y servicios críticos están bajo monitorización continua (logs, EDR/XDR, SIEM, NDR, etc.)?

- ☐ 0–20 %
- ☐ 21–50 %
- ☐ 51–80 %
- ☐ 81–99 %
- ☐ 100 % (incluyendo esos servidores que nadie quiere tocar).

5.3 ¿Mide la organización el tiempo medio de detección (MTTD) de incidentes de ciberseguridad de alta criticidad?

- ☐ No se mide.

- ☐ Se estima de forma aproximada en algunos incidentes.
- ☐ Se mide, pero sin objetivos formales.
- ☐ Se mide y se han fijado objetivos de mejora.
- ☐ Se mide, se comparan tendencias y se vincula a decisiones de inversión.

5.4 ¿Mide la organización el tiempo medio de respuesta (MTTR) para incidentes de alta criticidad?

- ☐ No se mide.
- ☐ Se mide ocasionalmente.
- ☐ Se mide con regularidad pero sin objetivos formales.
- ☐ Se mide con objetivos y se revisa en comités de seguridad.
- ☐ Se